

Final Grading Rubrics

Question 1

[2 × 9 = 18 Marks, Time: 40 Minutes]

Rubric:

1 Mark → Correct identification of a security threat

1 Mark → Correct explanation of the associated risk

0 Marks → If the threat is incorrect OR the explanation is irrelevant/vague

- a. Using a house security example, identify one threat and explain the associated risk.

Rubric:

1 Mark → Correct firewall type identified

1 Mark → Correct explanation of application-layer inspection

0 Marks → If firewall type is incorrect OR explanation does not match the firewall

- b. Which firewall type operates at the application layer and can inspect the content of HTTP or FTP traffic?

Rubric:

1 Mark → Correct identification of firewall type using SOCKS

1 Mark → Correct reason for not inspecting application-layer content

0 Marks → If firewall type or reason is incorrect

- c. Identify the firewall type that uses SOCKS and explain why this firewall design does not examine application-layer content

Rubric:

1 Mark → Correct execution steps of polymorphic malware

1 Mark → Correct execution steps of metamorphic malware

0 Marks → If malware types are confused or steps are incorrect

- d. Write execution steps to differentiate how polymorphic malware differs from metamorphic malware. Provide the steps for both in two side-by-side columns.

Rubric:

1 Mark → Correct IDS selection for each case (HIDS / NIDS)

1 Mark → Correct justification based on monitoring scope

0 Marks → If IDS selection or justification is incorrect

- e. A university's IT department faces two simultaneous issues:

- An attacker is suspected of modifying configuration files on a critical application server.
- The network team reports unusual inbound traffic spikes at the main campus router, possibly indicating an external attack.

For each case, identify the appropriate intrusion detection system and justify your choice.

Rubric:

1.5 Marks → Correct identification of SQL injection categories

0.5 Mark → Correct explanation of when each category is effective

0 Marks → If categories are incorrect or mixed

- f. Describe the three main categories of SQL Injection attacks. For each category, state when it is most effective for an attacker?

Rubric:

1 Mark → Correct Merkle–Damgård structure drawn

1 Mark → Correct labeling of components

0 Marks → If diagram is missing, incorrect, or unlabeled

- g. Draw the block diagram of the Merkle–Damgård hash construction and label its main components.

Rubric:

1 Mark → Correct authentication technique identified

1 Mark → Correct remaining security risk stated

0 Marks → If technique or risk is incorrect

- h. A system authenticates users by comparing the hash of the entered password with a stored value. Identify the authentication technique used and state one security risk that still exists even when hashes are used.

Rubric:

1 Mark → Correct role assignment explanation

1 Mark → Correct role activation through sessions

0 Marks → If RBAC process is incorrectly explained

- i. According to the RBAC reference model, explain how a user obtains permissions through roles and sessions.

Question 2

[5 × 2 = 10 Marks, Time: 30 Minutes]

- a. Suppose you lead a team of software developers and are very conscious about software security and want to give a small talk about defensive programming. Now answer the following questions that show your preparation on different topics.

Rubric:

1 Mark → Correct abstract execution model components

1 Mark → Correct identification of vulnerability points

0.5 Mark → Logical security flow explanation

0 Marks → If model is incorrect or not diagrammatic

- i. Draw an abstract model of a program in execution? Illustrates all potential points of vulnerability. Show all possible components for which security vulnerabilities could arise. {label diagram + vulnerabilities for two components (3 lines each)}. [2.5]

Rubric:

ANY ONE ATTACK needs to be answered. Students must explain “all parts of an attack and how it unfolds” because of 2.5 wt-age.

- ii. Explain the working of an exploit that is based on Operating System environment variables. [2.5]

- b. Make a cascading authorization graph based on the following description:

Rubric:

1.5 Marks → Correct cascading authorization diagram (entities, arrows, T-values)

1 Mark → Correct identification of grant option (*)

0 Marks → If diagram structure or grant option is incorrect

- i. You are given a cascading authorization scenario involving six entities (A, B, C, D, E, and F).
- A grants permissions to B (T=8, with grant option) and to C (T=10, no grant option).
 - B grants to D (T=10, with grant option).
 - C grants to E (T=22, with grant option).
 - D also grants to E (T=30, no grant option).
 - Finally, E grants to F (T=33, with grant option).

Using this description, draw the complete cascading authorization diagram showing all nodes,

Rubric:

1.5 Marks → Correct identification of revoked authorization path

1 Mark → Correct explanation of remaining valid paths

0 Marks → If cascading effect is incorrectly reasoned

- ii. Consider the cascading authorization scenario described above. Assume that at t=35 C revokes E's access rights, explain how this changes cascading authorization. Use arrows (e.g. A→B→D) [2.5]

Question 3

[3 × 2 = 6 Marks, Time: 30 Minutes]

An intrusion detection system (IDS) monitors approximately **1,000,000** security-relevant events each day. Out of these events, **100** represent actual intrusion attempts. The system successfully identifies **90** attacks, fails to detect **10**, and incorrectly flags **5,000** legitimate activities as malicious.

- a. **Identify the** false positive and false negative events generated by the IDS. Explain your answer.

Rubric:

1 Mark → Correct identification of false positives and false negatives

1 Mark → Correct explanation

0 Marks → If FP/FN values are incorrect

- b. **Explain how** this scenario illustrates the **base-rate fallacy**.

Rubric:

2 Marks → Correct explanation of base-rate fallacy

0 Marks → If explanation does not relate to base-rate fallacy

- c. **Identify the** suitable detection technique (*Signature* or *Anomaly-based*) for detecting known, previously observed attacks. Explain your answer.

Rubric:

1 Mark → Correct detection technique identified

1 Mark → Correct justification

0 Marks → If detection technique is incorrect

Question 4**[2 × 3 = 6 Marks, Time: 30 Minutes]**

A financial company operates multiple branches. A recent audit found that many branches use weak authentication, some servers store unencrypted customer data, and no standard security controls are applied across branches. Management wants a security method that provides quick baseline protection everywhere, and then allows deeper analysis only on high-risk systems.

Rubric:**1 Mark → Correct risk assessment approach identified****2 Marks → Correct and logically ordered steps****0 Marks → If approach or steps are incorrect**

- a. **Identify** the ONE risk assessment approach that best fits this situation. Explain all the steps that you follow in your proposed approach.

Rubric:**1 Mark → Correct technical control identified****2 Marks → Correct implementation steps****0 Marks → If control or steps are incorrect**

- b. **Identify ONE technical control needed to protect customer data** (domain hint: data protection). Explain the key implementation steps involved in deploying this control.

Question 5**[2 × 5 = 10 Marks, Time: 30 Minutes]**

- a. A cyber attacker first launches a phishing campaign using fake bank emails and successfully obtains login credentials of several customers of a public sector bank. Using these stolen credentials, he then gains unauthorized access to the bank's core database server. From the server, he copies confidential customer data, including CNIC numbers and account balances. To avoid detection and to further harm the victims, he later executes a malicious script that partially corrupts the transaction logs. Finally, he sends bulk fraudulent SMS messages to thousands of customers, impersonating the bank and asking them to urgently verify their accounts, resulting in financial losses to multiple individuals.

Rubric:**0.75 Mark × 4 → Correct PECA section + one-line legal reason****0 Marks → If section number OR legal reasoning is incorrect**

- i. From the given scenario, **write the FOUR MOST** relevant offences under the Prevention of Electronic Crimes Act (PECA) 2016 **by writing the correct Section Numbers, along with one precise legal reason for each section.** Use the format given below [3]

Rubric:**2 Marks → Correct identification and explanation of ONE law-enforcement challenge****0 Marks → If the challenge is incorrect or irrelevant**

- ii. Identify ONE major law-enforcement challenge highlighted by this scenario. (Answer in one to two lines only.) [2]

Rubric:**1.25 Marks → Correct ACM clause****1.25 Marks → Correct ethical reasoning****0 Marks → If clause or reasoning is incorrect**

- b. A smart surveillance system is deployed in a large public university to enhance campus security. The system uses facial recognition, real-time video analytics, and automated behavior tracking. Initially, it is approved only for security monitoring. Later, without informing students or staff, the system is upgraded to analyze private movement patterns and the summarized behavioral data is shared with a third-party analytics company for commercial research purposes. The university administration justifies this action by claiming that the data is only used to improve management efficiency and to generate revenue.

- i. Using the ACM Code of Ethics ONLY, **identify the violated ACM clauses** and **write one precise ethical reason** for each. **Note:** (Write one line per clause only.) [2.5]

Rubric:**1.25 Marks → Correct stakeholder identified****1.25 Marks → Correct ethical obligation stated****0 Marks → If stakeholder or obligation is incorrect**

- ii. Based on the above scenario and according to the **ACM Code of Ethics**, identify **ONE primary stakeholder affected AND state ONE ethical obligation owed to that stakeholder.** **Note:** (Write one line per item only.) [2.5]